htl donaustadt

Aufgabenblatt 2: Anwendung eines Unternehmens analysieren

Themenbezug: Datenschutz und DSGVO, Angriffsflächenanalyse, Linux-Berechtigungen, Code-Review, Threat Modeling mit STRIDE und Angriffsbaum, Serverhärtung und Defense in Depth

Bearbeitung: Beziehen Sie sich auf die im Briefing beschriebene Anwendung beziehungsweise das Kundenportal Ihres Unternehmens sowie deren Server- und Codebasis.

---

1. Datenschutz und Zweckbindung

Identifizieren Sie mindestens drei Datenkategorien aus der Beschreibung der Anwendung, die als personenbezogen oder als besondere Kategorie personenbezogener Daten gelten. Bewerten Sie für jede davon, ob die Erhebung für den beschriebenen Zweck erforderlich ist. Beschreiben Sie mindestens zwei daraus resultierende Pflichten des Anbieters gemäß DSGVO und nennen Sie mindestens eine weitere auf europäischer Ebene relevante Regulation, die für diese Anwendung von Bedeutung sein könnte. Schlagen Sie für mindestens eine problematische Datenkategorie eine datenschutzfreundlichere technische Umsetzung vor (zum Beispiel Datenminimierung oder eine Anpassung der Eingabemaske) und begründen Sie, wie diese die zuvor beschriebene Problematik entschärft.

2. Architektur- und Angriffsflächenanalyse

Analysieren Sie die im Briefing beschriebene Architektur der Anwendung (Frontend, Backend, Datenhaltung, Authentifizierung, Schnittstellen) und identifizieren Sie mindestens drei mögliche Angriffsvektoren. Erklären Sie die Begriffe „Vulnerability” und „Weakness” und ordnen Sie je mindestens ein Beispiel aus der Architektur den beiden Begriffen zu.

3. Serverseitige Zugriffsrechte

Der Server, auf dem die Anwendung läuft, weist die im Briefing angegebenen Datei- und Verzeichnisberechtigungen auf. Erklären Sie das zugrundeliegende Berechtigungsschema anhand von mindestens drei Beispielen aus der Auflistung. Ordnen Sie dieses Berechtigungssystem einem Access-Control-Modell zu und erläutern Sie mindestens zwei weitere Modelle im Vergleich dazu (zum Beispiel MAC und RBAC). Benennen Sie mindestens eine kritisch zu hinterfragende Berechtigung

und begründen Sie, warum diese problematisch ist. Schlagen Sie für diese Berechtigung eine konkrete technische Korrektur vor und begründen Sie, warum diese die Schwachstelle beseitigt, ohne die notwendige Funktion zu beeinträchtigen.

4. Code-Review

Identifizieren Sie in jedem der vorgelegten Codeausschnitte die jeweilige Schwachstelle und beschreiben Sie, wie ein Angreifer sie ausnutzen könnte. Erklären Sie dabei auch den Unterschied zwischen den in Ihren Codeausschnitten vorliegenden Schwachstellenarten (zum Beispiel Reflected- vs. Stored-XSS). Beschreiben Sie für jede gefundene Schwachstelle mindestens eine konkrete Härtungsmaßnahme. Bewerten Sie außerdem anhand der SQL-Abfrage im Login-Ausschnitt, wie das Passwort vermutlich in der Datenbank gespeichert wird, und erklären Sie, wie Passwörter stattdessen sicher gespeichert werden sollten. Berechnen Sie für eine der von Ihnen identifizierten Schwachstellen beispielhaft einen CVSS-Score anhand der Base-Metriken und erläutern Sie kurz, wie sich die einzelnen Metriken auf den Score auswirken.

5. Threat Modeling

Beschreiben Sie mindestens drei allgemeine, plausible Bedrohungsszenarien für die Anwendung. Wählen Sie eines davon als Oberziel eines Angreifers und zeichnen Sie dazu einen Angriffsbaum (Attack Tree), der mögliche Wege zu diesem Ziel darstellt. Wenden Sie anschließend das STRIDE-Modell auf die Anwendung an, ordnen Sie Ihre Bedrohungsszenarien den passenden STRIDE-Kategorien zu und erläutern Sie abschließend, wie die Entwickler STRIDE bereits während der Entwicklung nutzen könnten.

6. Serverhärtung und Defense in Depth

Erklären Sie das Prinzip Defense in Depth. Gehen Sie dazu von den im Briefing genannten, bereits aktiven Sicherheitsmaßnahmen Ihres Unternehmens aus und ordnen Sie diese den Ebenen Netzwerk, Betriebssystem, Anwendung und Daten zu. Identifizieren Sie für mindestens zwei dieser Ebenen jeweils eine Lücke und schlagen Sie eine passende Gegenmaßnahme vor.

Präsentieren Sie Ihre Ergebnisse anschließend in einer Präsentation von 10 bis 15 Minuten Dauer.